

August 24, 2026

To whom it may concern:

I am a faculty member in Computer Science at Stanford University and Co-Founder and CEO of Censys. I am also one of the original authors and a continuing maintainer of ZMap, the open-source high-speed network scanner, and of the surrounding ecosystem, including tools like ZGrab, DNS, and ZLint. ZMap underpins a large body of Internet measurement research and is widely used by researchers, operators, and security teams to discover and characterize hosts and services at scale. I write in support of the RedTwin proposal from Prof. Giovanni Vigna and Prof. Christopher Kruegel (UC Santa Barbara) and Prof. Adam Doupe and Prof. Tiffany Bao (Arizona State University).

Relationship to the proposing team. For full transparency: I know the PIs professionally through the academic security community and have collaborated with members of the team on unrelated research projects in the past. I am not part of the proposing team, hold no position at UCSB or ASU, am not a subawardee, have no current joint funding with the PIs, and would receive no funds under this award. My interest is as a maintainer of an open-source product that the proposed work would use and, I expect, improve.

Assessment of the proposed approach. The problem RedTwin addresses is one I have run into repeatedly from the measurement side: it is comparatively easy to enumerate what is exposed on a network, but it is much harder to say what an adversary could actually do with it. Answering the second question requires the kind of aggressive, stateful interaction that responsible practice forbids against production systems, which is precisely why so much security assessment stops at the inventory stage. The proposal's core move — reconstruct the deployment as a digital twin, confine all aggressive analysis to the twin, and keep every interaction with the live system passive — is the right structural answer, and the openness of the underlying software is what makes it feasible. I also think the team is right to treat the representativeness of the twin as a research problem in its own right, with explicit invariants and attack-graph preservation analysis: a twin whose fidelity is unquantified produces findings whose meaning is unquantified.

Relevance to ZMap. Thrust 1 needs to convert a live infrastructure into an accurate, continuously updated model: which hosts exist, which services they run, at what versions and with what configuration, and which reachability relations hold between them. That is close to what ZMap and ZGrab were built for, but the digital-twin setting imposes requirements that current ZMap does not fully serve, and those gaps strike me as genuinely interesting open-source engineering problems rather than mere plumbing:

- **Internal, non-disruptive discovery rather than Internet-wide sweeps.** ZMap was designed for stateless, single-packet, Internet-scale probing from outside. Enumerating an enterprise or campus network is a different regime: east-west rather than north-south, latency-sensitive workloads that must not be perturbed, and a hard non-disruptiveness requirement. Adaptive rate control, constraint handling, and probe budgets driven by an explicit cost model — as the proposal's observation-planning formulation contemplates — would be of interest to ZMap users well beyond this project.
- **Fingerprinting depth sufficient to drive replication.** A twin needs more than “port 443 is open.” It needs the specific package, release, and build configuration, since that determines the vulnerability surface to be reproduced. Version-precise application-layer characterization, and output that can populate a structured knowledge graph directly, would be a real advance.
- **Reachability, not just host inventory.** The proposal's knowledge base is a graph of hosts, services, segments, credentials, and trust relations. Scanning that is *aware* of vantage points, running the same

probes from multiple positions to establish reachability rather than mere liveness, is a capability the ZMap ecosystem does not have today.

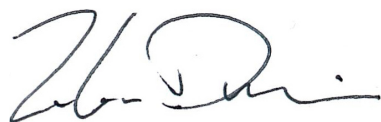
- **Continuous, differential operation.** Because the twin must track an evolving target, the interesting output is the *delta*. Efficient incremental rescanning and change reporting would fit the toolchain naturally.

My contribution to the open-source product. I co-authored ZMap and continue to maintain it: I have guided its technical direction, reviewed and merged community contributions, and supported the large research and operator community that depends on it.

What I would expect if the proposal is funded. The most likely and most useful form of interaction, in my view, is upstreaming. If the team develops probe modules, structured output formats, incremental-scan support, or constraint handling for this work, those contributions would be welcome through the project's normal review process, so that the capabilities built for RedTwin become available to all ZMap users rather than living in a fork. I would also be glad to be a source of advice on scanning methodology — rate control, vantage-point selection, probe-module design, and the ethics and safeguards that should govern any observation of operational networks — since these are areas where mistakes are easy to make and consequential. Finally, the observation-planning and fingerprinting results here are of independent interest to the Internet-measurement community, and I would expect them to find an audience there.

This is a well-conceived project addressing a real gap, and I expect the open-source ecosystem I help maintain would be better for it. I am glad to support it.

Sincerely,



Zakir Durumeric

Assistant Professor, Computer Science
Stanford University